Use Case Specification: UC-01

- **ID / Code:** UC-01
- **Use Case Name:** Log In to Portal
- **Description:** Allows an internal user (Base User, Administrator or Super-Administrator) to authenticate in the portal using their verified corporate email address and password, enforcing session security and brute-force protection.
- **Primary Actor:** Base User (inherited by Administrator and Super-Administrator)
- **Scope:** Subscription Management & Invoicing System
- **Level:** User Goal
- **Stakeholders & Interests:**
  - *Base User:* Wants fast and simple access to the portal to work with their assigned clients and sections (UR-1.1).
  - *Company (Product Owner):* Wants confidential billing and customer data to be accessible only to authorized staff (NFR-5.1).
  - *Super-Administrator:* Wants access attempts to be controlled and suspicious behaviour to be blocked automatically (FR-7.5.3).
- **Preconditions:** The user has an active account registered in the system with a verified corporate email address.
- **Postconditions:** An authenticated session associated with the user's role and permissions is created.
- **Success Guarantee:** The user is authenticated, a new session with an inactivity timeout (FR-7.5.1) is started, and the user is redirected to the dashboard (UC-03) showing only the data their permissions allow.
- **Minimal Guarantee:** No session is created for invalid credentials; credentials are never stored or logged in plain text, and every failed attempt is recorded for security auditing.
- **Trigger:** The user opens the portal URL or selects "Log In".
- **Main Success Scenario:**

1. **User:** Requests to log in to the portal.
2. **System:** Displays the login form requesting corporate email and password.
3. **User:** Enters their credentials and submits the form.
4. **System:** Validates that both fields are filled in and correctly formatted.
5. **System:** Verifies that the account is active and not temporarily blocked, and checks the credentials against the stored (hashed) values.
6. **System:** Creates an authenticated session linked to the user's role and permissions and starts the inactivity timer (FR-7.5.1).
7. **System:** Redirects the user to their dashboard (UC-03).

- **Extensions:**
  - 4a. Empty or malformed fields:
    - 4a1. System highlights the invalid fields with an understandable error message (NFR-1.7).
    - 4a2. User corrects the data; the flow resumes at step 3.
  - 5a. Incorrect credentials (first or second consecutive failure):

- 5a1. System records the failed attempt.
- 5a2. System shows a generic message (“Incorrect email or password”) without revealing which field was wrong.
- 5a3. The flow resumes at step 3.

▸ 5b. Third consecutive failed attempt:

- 5b1. System temporarily blocks authentication for that account for the configured duration (e.g., 5 minutes) (FR-7.5.3).
- 5b2. System informs the user of the temporary block and the remaining time.
- 5b3. The use case ends without creating a session.

▸ 5c. Account deactivated or guest account expired (FR-7.4):

- 5c1. System rejects access and informs the user that the account is not active.
- 5c2. The use case ends.